Security overview

Customer-hosted. Agents and people use the control-plane API. The database stays on the private network.

Trust boundary

The software runs in the customer's environment: a VM, bare metal, Docker Compose, or Kubernetes. The customer controls the network, backups, and secret storage. Agents register, send a heartbeat, claim work, and post the result through the API. They never receive database credentials.

Who can act

Control	What it does
Viewer	Read definitions, history, and agents. Cannot create, edit, run, schedule, or remove them, even as a workspace owner.
Operator	Run, cancel, and requeue. Create and edit in workspaces they manage. Register and remove agents.
Admin	Every workspace. Users, groups, agent pools, the definition file, and deletes of jobs and groups.
Workspaces	A second limit. Personal, group, and platform. Membership in one group does not open another group's jobs.
People	Local accounts, or OIDC from Entra ID, Okta, or Keycloak. SSO-only sign-in is supported. Groups in the identity provider become the sign-in role.
Remote agents	A confidential client and a short-lived token. The control plane and the token address must be HTTPS. The agent does not use a person's password.
Private network	Agents on the private network may use a local operator login. A public entrance can refuse that password.
API catalog	Administrators see it. Operators and the agents call the API. Viewers do not.
Audit	Creates and updates of jobs, workflows, and schedules record the person, the time, and the fields before and after.

The account that runs the command

- Agents open an outbound connection. The control plane does not dial the host, and no inbound agent port is required.
- On Linux the agent refuses to start as root. A command is the shell inside that process, so the job has only that account's rights.
- There is no setting to run one job as a different user. Two jobs that need different rights use two agents.
- The packaged containers drop extra privileges, refuse new privileges, and keep the root filesystem read-only.
- The customer still owns the script and the rights of the account the agent runs as.

Data

Definitions, payloads, logs, and history stay in the customer's deployment. Just Run It does not require a multi-tenant service to run production work. If logs are shared for a support ticket, they are used to resolve that ticket.

Production hardening

Item	Recommendation
TLS	Terminate HTTPS in front of the control plane.
Database	PostgreSQL on a private network, with backups.
Passwords	Change any bootstrap passwords before production use.
Agent account	A dedicated operating-system account with only the rights that account's jobs need.
Agent sign-in	A confidential client for remote agents. Keep a local operator login on the private network only.
Network	Allow agents to reach the control-plane API. Restrict the admin UI where policy requires it.
People	Prefer company SSO, with the identity provider's own sign-in controls.

Reviewers should see an API-only path to the workers, a private database, a sign-in role plus a workspace, and a command that runs as a normal account rather than as root.